CAMPUSCLAW · 实现方案

# 基于 Token 的身份认证与知识库问答

本文对照仓库当前实现，说明访问令牌如何签发、携带、校验和撤销，以及本班教研资料如何切分、检索，并生成带出处的回答。认证结果是问答的前置条件：班级只来自已校验的会话，不来自请求参数。


姓名

杨瑾文

学号

2601110896


项目

CampusClaw

日期

2026 年 10 月 8 日

# 目录

1 方案概述

2 运行结构与信任边界

3 基于 Token 的身份认证

4 基于知识库的问答

5 认证对问答的约束

6 接口与状态码

7 小结

## 1 方案概述

CampusClaw 是面向班级教研的单进程应用。浏览器与 JSON 接口由同一个 Python 进程提供，关系数据放在 SQLite，切片向量放在 Qdrant。身份和问答共用这一条信任链：先确认调用者是谁，再按库中的角色和班级执行操作。

身份认证采用签名访问令牌，并在服务端保留可撤销的会话行。登录校验通过后，`app/security.py` 用 `SESSION_SECRET` 签发 HS256 JWT，`app/server.py` 只把该令牌的 SHA-256 写入 `sessions`。浏览器把明文令牌放在 `localStorage`，之后以 `Authorization: Bearer` 发送。每个业务请求都要同时通过签名校验和会话表查找；登出删除会话行，旧令牌立即失效。

知识库问答建立在已登录用户的本班资料上。教师上传的 `.txt` / `.md` 先写入材料表和知识条目表，再按策略切成切片。切片正文留在 SQLite，向量与标识写入集合 `campusclaw_chunks`。`POST /api/ask` 只用会话中的班级做混合检索，取前 4 条切片组织上下文，由对话网关生成带 `[1]`、`[2]` 的简短回答。检索为空时返回「资料中未找到相关内容」，并且不调用对话模型。

## 2 运行结构与信任边界

进程入口是 `run.py`。它加载配置、确认数据库已初始化、按 `EMBEDDING_DIM` 幂等创建 Qdrant 集合，并为尚未切分的材料按 auto 策略补索引，然后启动 `ThreadingHTTPServer`。缺省监听 `127.0.0.1:5000`。Compose 中 Web 与 Qdrant 分属两个服务，Qdrant 的 6333 端口不映射到宿主机，向量库只供应用容器访问。




图 1　模块划分。路由层只做会话装配和参数校验，检索与生成不反向依赖 HTTP 处理。

信任边界落在请求处理函数，不落在页面按钮上。静态资源只有 `/`、`/index.html`、`/static/style.css`、`/static/app.js` 四条白名单。`data/uploads/` 不能被 URL 直接打开，原文件只能经过材料下载接口。响应统一带上 `X-Content-Type-Options: nosniff`、`X-Frame-Options: DENY` 和仅允许同源脚本样式的 CSP。

配置由环境变量优先、根目录 `.env` 补充。`SESSION_SECRET` 为空或仍是模板占位符时进程直接退出。嵌入与对话的 Base URL、密钥、模型名，以及 Qdrant 地址，都只在服务端读取。

# 3　基于 Token 的身份认证

## 3.1　令牌与会话各管一件事

访问令牌是一段 HS256 JWT，用来证明「这份凭证由本服务签发，且未超过声明的过期时间」。会话表用来决定「这份凭证现在是否仍被接受」。两者一起用：签名保证令牌不能被改写，会话行保证登出和过期可以立即生效。JWT 里的角色和班级供客户端展示，并用来核对用户编号；授权时的角色和班级以数据库联表读出的用户行为准。

| 对象 | 保存位置 | 内容 |
| --- | --- | --- |
| 口令 | `users.password_hash` | PBKDF2-HMAC-SHA256，含算法名、迭代次数、盐和摘要 |
| 访问令牌明文 | 浏览器 `localStorage["cc_token"]` | header.payload.signature，不下入库 |
| 令牌指纹 | `sessions.token_hash` | 整段 JWT 的 SHA-256，唯一索引 |
| 签名密钥 | 环境变量 `SESSION_SECRET` | 只参与 HMAC，不出现在响应里 |

## 3.2　口令校验

`hash_password` 用 16 字节随机盐和 200000 次迭代计算 PBKDF2-HMAC-SHA256，存储格式为：

```
pbkdf2_sha256$200000$<salt hex>$<digest hex>
```

`verify_password` 按记录中的算法、迭代次数和盐重算摘要，并用 `hmac.compare_digest` 比较，避免逐字节提前返回。用户名不存在时，`dummy_verify` 仍执行一次相同迭代次数的哈希，使「无此用户」和「口令错误」的

耗时接近。种子账号由 `scripts/init_db.py` 写入，角色只有 `teacher` 与 `student`，每人绑定一个 `class_id`。

## 3.3 登录、签发与限流

`POST /api/login` 接收 JSON `{"username","password"}`。用户名会去掉首尾空白；缺字段、空用户名或空口令返回 400。通过校验后的步骤如下。

1. 以 `(客户端 IP, 用户名)` 为键检查进程内滑动窗口。默认 900 秒内失败达到 5 次即视为受限，仍执行一次哑哈希，然后与普通失败返回同一句错误。
2. 按用户名查询 `users`。不存在则哑哈希并记一次失败；口令不匹配则记一次失败。
3. 成功后清掉该键的失败记录，调用 `issue_access_token`。有效期默认 `SESSION_TTL_SECONDS=28800`（8 小时）。
4. 把令牌 SHA-256、`user_id`、`created_at`、`expires_at` 插入 `sessions`。
5. 响应 200，正文包含 `token`、`token_type: "Bearer"`、`expires_in`，以及用户名、角色、班级编号和班级名称。

失败响应始终是 `401 {"error":"用户名或密码错误"}`。账号不存在、口令错误和触发限流使用同一状态码和同一文案，不返回 429，避免用状态码区分账号是否存在。限流计数保存在进程内存中，按单进程部署使用。

JWT 头固定为 `{"alg":"HS256","typ":"JWT"}`。载荷字段为：

```
{
  "user_id": <int>, "username": "...", "role": "teacher|student",
  "class_id": <int>, "iss": "campusclaw", "sub": "<username>",
  "iat": <unix>, "exp": <unix>
}
```

签名输入是 header 与 payload 两段 Base64URL 用点号连接后的 ASCII 字符串，HMAC-SHA256 的密钥是 `SESSION_SECRET`。解码时拒绝 `alg` 不是 HS256 的头，从而不接受算法切换。签发方必须是 `campusclaw`，`exp` 必须是尚未到期的整数。任一环节失败都返回 `None`，不把异常抛给调用方。

## 3.4 后续请求如何确认身份

前端 `authHeaders()` 读取 `cc_token`，有值时设置 `Authorization: Bearer <token>`。服务端 `current_user()` 按下面的顺序接受或拒绝：

1. 请求头方案名必须是 Bearer，令牌非空。
2. `decode_access_token` 校验算法、签名、签发方和 `exp`。
3. 用令牌的 SHA-256 查询 `sessions`，并连接 `users`、`classes`，取出当前用户名、角色、班级和会话过期时间。
4. 会话行不存在，或 `expires_at` 已到，视为未登录。

5. JWT 中的 `user_id` 必须等于会话所属用户。通过后返回这一行，后续授权使用其中的 `role` 与 `class_id`。

`require_user()` 在未通过时直接响应 `401 {"error":"未登录或会话已过期"}`。页面启动时先请求 `GET /api/me`：成功才进入应用，失败则回到登录页。业务接口返回 401 时，前端删掉本地令牌并回到登录页。因此刷新页面后的身份以服务端重读结果为准，不靠前端缓存的角色。

> 教师上传按钮由前端按 `/api/me` 的角色隐藏，学生直接调用 `POST /api/materials` 或重建索引时，服务端仍返回 403。隐藏按钮只影响界面，不构成访问控制。

### 3.5 登出

`POST /api/logout` 读取 Bearer 令牌，按哈希删除 `sessions` 中对应行，并返回 204。没有令牌时同样返回 204。删除之后，签名仍在有效期内的旧 JWT 无法再通过会话表查找，下一次业务请求得到 401。前端在调用登出接口后清除 `cc_token`。

### 3.6 认证之后的角色与班级

角色检查写在具体接口上。上传材料和重建索引要求 `role == "teacher"`，否则 403。列表、详情、下载、检索和问答只要求已登录，教师和学生都可以使用。

班级隔离使用会话中的 `class_id`。材料详情和下载的 SQL 同时约束材料编号和班级；另一班的编号与不存在的编号都是 `404 {"error":"未找到材料"}`，响应里不包含对方标题、正文或磁盘路径。检索和问答会丢掉查询串、JSON 体和 `X-Class-Id` 中另带的班级编号，只把会话班级传给检索函数。

## 4 基于知识库的问答

### 4.1 问答回答的是本班切片，而不是整库闲聊

问答链路分成入库、检索、生成三段。入库把一篇材料变成可定位的切片；检索在本班已就绪切片里找出依据；生成只在有依据时发生，并把依据编号写进回答。对话组件不自己查数据库或向量库，上下文由 `retrieval.py` 组装。

| 数据 | 存放 | 问答时的用途 |
| --- | --- | --- |
| 材料元数据与原文件 | `materials`，磁盘 `data/uploads/` | 标题、下载；出处点击后打开详情 |
| 上传原文 | `knowledge_entries.content` | 切分输入；详情页展示全文 |
| 切片正文与字符区间 | `knowledge_chunks` | 关键字检索、摘录、引用定位 |
| 向量与标识 | Qdrant `campusclaw_chunks` | 余弦检索；payload 不含正文 |

Qdrant 每个点的主键与切片主键相同。payload 只有 `class_id`、`material_id`、`entry_id`、`chunk_id`、`chunk_index`。摘录永远从 SQLite 的 `chunk_text` 截取，最长 160 字，超出加省略号。

## 4.2 上传后的切分与索引

教师上传时，服务端只接受 `.txt` 与 `.md`，正文必须是 UTF-8，大小上限默认 2 MiB。扩展名非法为 415，超限为 413，非 UTF-8 或切分参数不合法为 422。通过校验后，在同一事务中插入 `materials` 与 `knowledge_entries`，提交后再把临时文件原子换到 `data/uploads/<id>.<ext>`。换名失败会删掉刚写入的两行，避免库里留下没有文件的材料。

事务提交之后同步索引，分四步：

1. 按本次策略把正文切成切片，字符区间记在 `char_start`、`char_end`。
2. 切片先以 `embed_status='failed'` 写入 `knowledge_chunks`。此时材料已经保留，索引失败不会删材料。
3. 逐片调用嵌入网关。返回维度必须等于 `EMBEDDING_DIM`，然后以切片编号为点主键写入 Qdrant。
4. 写入成功才把该切片改为 `ready`。嵌入或向量库失败则删除可能写出的残点，状态保持 `failed`。响应给出 `chunks_total`、`chunks_failed`、`chunks_ready`。

未配置嵌入网关时，切片全部保持 failed，上传本身仍然成功。只有 `ready` 的切片参与关键字检索和向量检索。

| 策略 | 规则 |
| --- | --- |
| `auto`（默认） | 窗口最长 800 字，重叠 80 字。优先在空行、换行、句号处断开。请求里另带的长度和预处理参数被忽略。 |
| `custom` | 分隔符为换行、空行或句号之一。最大长度 100 – 2000，重叠比例 0% – 50%。可选去掉 URL 与邮箱、把连续空白折成一个空格。越界返回 422。预处理后的字符区间相对预处理文本，不当作原文件下标。 |
| `hierarchy` | 按 Markdown 一至三级标题分章，标题留在该章切片内。没有标题时退回 auto。单章超过 800 字再按 auto 细切。 |

切分只读正文。原文和上传文件保持原样。更换策略或补齐失败切片时，教师调用 `POST /api/materials/{id}/reindex`。该接口先按 `material_id` 删除 Qdrant 中该材料的点，再删除旧切片行，然后按本次参数重新入库。已有切片的材料在进程启动时不会被自动重切；`backfill_unchunked` 只处理还没有任何切片的材料。

## 4.3 三种检索

`GET /api/search?q=&mode=` 要求已登录。空查询返回 400。`mode` 只能是 `keyword`、`vector`、`hybrid`，缺省为 hybrid。每路最多保留 8 条。

关键字。问句抽出长度至少为 2 的连续中文、字母和数字，去重后作为词元。SQL 只选择会话班级且 `embed_status='ready'` 的切片，用 `LIKE` 做词面过滤。相关度为各词元「出现次数 × 词元长度」之和，相关度为 0 的丢弃，再按分数降序、切片编号升序截断。这一路不调用嵌入，也不访问 Qdrant。

向量。问句经 OpenAI 兼容的 `POST /embeddings` 得到向量，再请求 Qdrant `points/search`。过滤条件是 payload 的 `class_id` 等于会话班级，距离为余弦，`score_threshold` 为 0.35，不返回向量本身。回到 SQLite 时再次要求切片编号属于这些点、班级仍是会话班级、状态为 ready。向量库里即使出现他班点，回表也取不到正文。

混合。两路各自过滤、各自排序后按名次做倒数排名融合，常数 k 为 60：

score(切片) = Σ 1 / (60 + 该切片在该路中的名次)

某一路没有出现的切片，这一路不加分。两路原始分数不相加。融合后再按分数降序、切片编号升序。双路都出现的切片会得到两份贡献，因此更靠前。

嵌入网关或 Qdrant 不可用时，vector 与 hybrid 返回 `503 {"error":"服务暂时不可用"}`，不编造分数。keyword 仍只依赖 SQLite。跨班检索得到 `200` 和空的 `hits`，不用 403 或 404 暗示其他班有这份内容。

## 4.4 从命中切片到回答

`POST /api/ask` 的正文是 JSON。问题取 `question`，为空时回退到 `q`。都为空则 400。可选的 `messages` 只保留 `user` 与 `assistant`，每条内容截到 4000 字，最多留下最近 6 条；客户端提交的 system 角色被丢弃。若历史最后一条与本轮问题相同，则去掉，避免把当前问题重复放进上下文。

1. 用本轮问题在会话班级上做 hybrid 检索，只取前 4 条。
2. 零命中时直接返回 `{"answer":"资料中未找到相关内容","citations":[]}`。此分支不读取对话配置，也不请求对话网关。
3. 有命中但 `CHAT_BASE_URL`、`CHAT_API_KEY`、`CHAT_MODEL` 任一缺失，返回 503。
4. 服务端写入固定 system 提示：只根据给出的资料切片回答，依据处用与资料编号一致的 `[n]`，资料没写到的不要编造。
5. 用户消息按 `[1]…`顺序拼上材料标题、切片序号和切片正文，再附上问题。然后附上清洗后的历史。
6. 以温度 0.2、非流式调用 `POST /chat/completions`。超时、网络错误、空回答或无法解析时返回 503，不补一句编造的答案。

模型返回后，`align_citations` 扫描回答里的 `[n]`，按首次出现顺序收集落在命中范围内的编号，并重编号，使文中的 `[1]` 对应 `citations[0]`。越界编号从回答中去掉。若模型完全没有标出合法编号，则按检索顺序为全部命中补上标记，避免出现有依据却没有出处列表的回答。每条 citation 含 `material_id`、`material_title`、`chunk_id`、`chunk_index`、`char_start`、`char_end`、`excerpt`、`score`。摘录由服务端截取，不接受客户端提交的出处。




图 2　一次提问的三段。中间一段为空时，第三段不执行。

## 4.5 页面上的检索与提问

登录后「知识问答」进入独立面板，标题写的是当前班级。检索页提供关键字、向量、混合三个模式，默认混合，结果卡片显示材料标题、切片序号、字符区间和摘录。问答页把问题与最近对话提交到 `/api/ask`，回答中的 `[n]` 高亮，下方按 citations 顺序列出出处。点击出处调用已有的材料详情接口；该接口仍按会话班级查询，跨班材料编号得到 404。前端把成功的问答追加进本地 `askMessages`，最多保留 6 条，供下一轮作为历史提交。清空对话只清页面状态，不改知识库。

## 5 认证对问答的约束

检索和问答没有匿名入口。`_handle_search` 与 `_handle_ask` 都先调用 `require_user()`，未通过则不再解析问题。通过之后，班级只使用 `user["class_id"]`。请求里另带的 `class_id`、`classId` 会从查询串或 JSON 中删除，`X-Class-Id` 读出后不参与查询。

班级条件在检索的两侧各写一次。关键字 SQL 的 `WHERE` 含 `c.class_id = ?`。向量检索的 Qdrant filter 含同一班级，回表 SQL 再次加上 `c.class_id = ?` 和 `embed_status = 'ready'`。因此向量库过滤和正文库过滤互相复核：一侧漏掉时，另一侧仍然拿不到他班正文。

出处打开的是材料详情或文件下载，这两条接口沿用认证后的班级联合查询。问答列表里出现的 `material_id` 若被改去请求他班材料，详情接口返回与「材料不存在」相同的 404。学生可以检索和提问，不能上传，也不能重建索引。

密钥不下发。嵌入密钥和对话密钥只出现在服务端发往网关的 `Authorization` 头中。接口响应和页面都不包含向量分量。调用日志只有 `[EMBED] POST /embeddings`、`[QDRANT] POST points/search`、`[CHAT] POST /chat/completions` 这类短标记，不打印密钥，也不打印送入模型的切片正文。

## 6 接口与状态码

| 方法与路径 | 谁可以调用 | 成功时 | 常见失败 |
| --- | --- | --- | --- |
| `POST /api/login` | 匿名 | 200，返回 Bearer 令牌与身份 | 400 格式；401 同形失败 |
| `POST /api/logout` | 持有令牌时删会话 | 204 | 无令牌也是 204 |
| `GET /api/me` | 已登录 | 用户名、角色、班级 | 401 |
| `POST /api/materials` | 教师，本班 | 201，含切片统计 | 401 / 403 / 413 / 415 / 422 |
| `POST /api/materials/{id}/reindex` | 教师，本班 | 200，重建后的切片统计 | 401 / 403 / 404 / 422 / 503 |
| `GET /api/search` | 本班师生 | 200，`mode` 与 `hits` | 400 / 401；向量或混合依赖故障 503 |
| `POST /api/ask` | 本班师生 | 200，`answer` 与 `citations` | 400 / 401；有命中但对话不可用 503 |
| `GET /api/materials/{id}` | 本班师生 | 详情与知识库正文 | 401；跨班或不存在 404 |

数据库异常时，`/api/` 返回 503。`GET /health` 只表示进程存活，不查库，也不要求登录。

| 常量 | 值 | 所在位置 |
| --- | --- | --- |
| 口令迭代 / 盐长度 | 200000 次，16 字节 | `security.py` |
| 会话有效期 | 默认 28800 秒 | `SESSION_TTL_SECONDS` |
| 登录失败窗口 | 5 次 / 900 秒，键为 IP 与用户名 | `LoginRateLimiter` |
| 向量分数下限 | 余弦 0.35 | `VECTOR_MIN_SCORE` |
| 融合与候选 | RRF k=60，每路 8 条；问答取前 4 条 | `retrieval.py` |
| 摘录 / 对话历史 | 摘录 160 字；历史最多 6 条 | `retrieval.py` |
| 默认切分 | 800 字窗口，80 字重叠 | `chunking.py` |

## 7 小结

认证方案把可校验的 HS256 访问令牌和可删除的服务端会话行放在一起。浏览器只保存并发送令牌；服务端每次用签名确认令牌未被篡改、未过期，再用令牌哈希确认会话仍在，最后从用户表读出角色和班级。登出删行之后，未到期的旧令牌不能继续访问。

问答方案把正文和向量分开存放，先在本班 `ready` 切片上做关键字与向量检索，再按名次融合。只有命中前 4 条切片时才调用对话网关，回答中的编号与出处列表对齐，出处可以打开对应材料。没有依据时返回固定文案。班级在会话、关键字 SQL、向量过滤和回表四处使用同一来源，因此问答的范围就是当前登录用户所属的班级。